CONSULTATION 16 OCT 2026 · RESPONSE LEDGER

Every Panel Recommendation, Answered

Twenty-six recommendations from three panelists. Sixteen implemented, four already present in the system, four declined on technical grounds, three not yet built. Each entry says what was asked, what was done, and — where nothing was done — why.

Panel Sir Ezeck · Ma'am Nayre · Sir Aldrin **System** Barangay 591 e-Services Portal

Regression 40 / 40 passing

Tally

[IMPLEMENTED — 16] [ALREADY PRESENT — 4] [DECLINED WITH REASONS — 4]

[NOT YET BUILT — 3]

These categories differ in kind, and the difference matters. **Declined** means the recommendation cannot or should not be done as described, and each of those four entries carries the argument — in two cases another panelist independently proposed the solution that replaces it. **Not yet built** covers three items, and they are not alike: push notifications and configurable module permissions are the two largest pieces of work raised and were sequenced last, with nothing blocking them but time. Bulk registration is different — examining the registration flow showed it would add no capability the system lacks while introducing a risk it does not currently have, so it is held open for the panel to decide rather than simply queued.

Sir Ezeck

Ten recommendations, centred on the verification workflow and the assistant's knowledge base.

OCR confidence is meaningless — name alone already reads 80%

[IMPLEMENTED]

> *"nung tinest pangalan pa lang mataas na percentage nasa 80% agad — kailangan may condition siya… gagawan ng checklist or formula… yung metrics ang kailangan dyan"*

Correct, and it was a real defect rather than a tuning problem. The score was hardcoded as **80% name plus 20% address**, so any document carrying the resident's name scored exactly 80 regardless of what else it proved.

Scoring is now the sum of fields each document type declares, and a missing **required** field blocks a full match however high the total. Staff see the per-field checklist with weights, which is the "show more OCR information" view that was asked for.

```
scenario                      old    new    verdict
name only  (the reported case)  80%    45%    PARTIAL
name + birthdate                80%    65%    PARTIAL
name + birthdate + licence no.  80%    80%    MATCH
full document                  100%   100%    MATCH
```

Set conditions per ID type via a dropdown

[IMPLEMENTED]

> *"if may field don mag drop down na lang kayo kung anong iuupload na ID… if drivers license doon na kayo magseset ng conditions tas pag PSA ibang field naman"*

Each accepted document type now carries its own field specification, so a driver's licence is checked for a licence number while a PSA birth certificate is not. Judging unrelated documents against one checklist was part of what made the old number meaningless.

Approval needs a comment, rejection needs justification

[IMPLEMENTED]

> *"pag approve kailangan ng comment pag reject it needs justification"*

Enforced on the server, so it cannot be bypassed through the API. Rejections are held to a longer minimum than approvals, because the text is sent to the resident as the reason to fix.

This replaced a generic email that guessed — *"Common reasons: the photo is blurry, details are cropped…"* — with the reason staff actually gave, shown both in the email and in the portal.

Confirmation prompts before an OCR decision

[IMPLEMENTED]

> *"Confirmation prompts sa OCR"*

Approving and rejecting were single clicks. Both now open a dialog that states the consequence plainly — approval unlocks every service for that resident — and collects the decision note before proceeding.

Audit log with reasons on OCR decisions

[IMPLEMENTED]

> *"Audit log and description reasons sa OCR"*

Audit entries already recorded the actor and verdict. They now also carry the score and the staff member's reason, so a reader can see what the cross-check reported *and* why staff agreed or overrode it. The automated OCR entry additionally names which fields matched.

```
Rejected Verification
Resident: A. Potolin · Birth Certificate (PSA) · OCR NO_MATCH (0%) ·
Reason: The uploaded image is blank — no name or ID number is readable.
```

Drop PDFs from OCR, accept images only

[ALREADY PRESENT]

> *"Sa ocr sa pdf ireremove na lang lalagay na lang image jpeg or png"*

PDFs were already excluded from OCR and routed to manual staff review rather than being scored, so the concern was already handled. Worth demonstrating rather than rebuilding.

A friendly editor so non-technical staff can add knowledge

[IMPLEMENTED]

> *"Since di technical si secretary… gawing user friendly sa adding knowledge base… gumawa ng generator to feed that particular file"*

The knowledge screen now opens on **"Write it here"** rather than a file box. Staff give the topic a name and add plain question-and-answer pairs; the system composes the Markdown and publishes it. A preview shows exactly what will be saved, and the file upload remains for anyone who already has a prepared document.

This also resolves Sir Aldrin's request for PDF support without needing PDFs — nobody edits markup, and the stored knowledge stays plain reviewable text. The composer publishes through the same endpoint as a manual upload, so it adds convenience without bypassing the review path.

Bulk registration by emailed invitation

[NOT YET BUILT]

> *"Bulk registration enter their respective email address on behalf of the person… may magsesend sa kanila ng link para makapag proceed sa registration"*

Deliberately not built, for reasons that emerged from examining how registration actually works rather than from effort.

It would add no capability. Residents already self-register against the Barangay Census: anyone whose record exists can create an account unaided, and anyone whose record does not is told so and directed to the Barangay Hall. Nobody is blocked today, so an invitation would be a second route to a destination already reachable.

The email confirmation it promises already exists. The stated purpose was to "confirm that email" by sending a link. Two-factor sign-in does exactly that, on *every* login — an account whose address was mistyped cannot be signed into a second time. Adding a confirmation link would duplicate a mechanism already built and tested.

And it would introduce a risk the current flow does not have. Staff typing a resident's address on their behalf means a mistyped address sends a link, bound to a real census record, to a stranger — who could then claim that person's identity. Self-registration at least requires knowing the resident's name and birthdate. The existing verification gate limits the damage, but the vector would be new.

The real problem underneath it was fixed instead. The friction Sir Ezeck saw is genuine: self-registration demanded the resident's name *exactly* as the census stores it, and anyone whose current name differed was turned away by a system that already held their record. An invitation papers over that for invited residents only. Correcting the census matcher — which was done — solves it for everyone, including walk-ins, and resolved a related defect where a resident who married was duplicated and locked out on the next census refresh.

Status: left open rather than closed, because the panel asked for it and the decision is theirs. The recommendation is to discuss the trade-off before building: a convenience layer that costs an identity-claim vector, against a friction point already resolved another way.

Say "LLM" instead of "NLP" in the objectives

[DECLINED — PREMISE]

> *"Dapat nilagay niyo LLM kesa sa NLP kasi ang NLP may sentiments… irevise niyo yung objectives"*

Sentiment analysis is **one task within** natural language processing, not its definition. A large language model *is* NLP, and the system's intent classification, language detection, and fuzzy name matching are all classical NLP. There is no either/or to choose between.

The procedural advice is accepted in full: objectives should not change without the panel's agreement. The recommendation is to satisfy that by describing the system accurately as a hybrid — which is what the implementation genuinely is — rather than by swapping one label for another.

Automate knowledge feeding with no human intervention

[DECLINED — SAFETY]

> *"Iautomate niyo na lang yon iauto feed nyo sa AI ganon para wala ng human intervention"*

The interface is accepted; the automation is not. Knowledge files are injected **directly into the assistant's instruction prompt**, which makes the upload path a trust boundary rather than a data import.

Automatic ingestion of unreviewed content is precisely the mechanism that would let injected text reach *every* resident's answers instead of only the sender's own screen — converting a self-inflicted prompt attack into one affecting the whole barangay. It also sits oddly against the same panelist's request for justification on approvals: it would place zero review on the one input that rewrites the assistant's rules.

Ma'am Nayre

Endorsed Sir Ezeck's first six points, and added two of her own.

Row filtering and search on the ARTA dashboard

[IMPLEMENTED]

> *"filter search sa rows sa arta employee dashboard and other na required na ganon if need"*

Filters were added to the **ARTA SLA Tracker on the employee dashboard** — the screen staff work from — and to the admin ARTA report. Search matches request title or resident name, and a second filter narrows by deadline: overdue, due within 24 hours, or on track.

Both run **server-side**. The tracker paginates at five rows, so filtering only the visible page would have narrowed what staff could see while under-reporting the real backlog. The empty state distinguishes "nothing matched your filter" from "queue is clear", which would otherwise tell staff there was no work outstanding.

Admin control over which modules each employee role sees

[NOT YET BUILT]

> *"Add or remove modules ng employee side na nacocontrol ng admin side ex. walang sos map si lupon tagapamayapa"*

A legitimate feature. Navigation is currently fixed per role, so per-position control means a real permissions model: storage, enforcement on every protected route, and an administration screen.

Why not yet: one of the two largest items raised, and purely additive — nothing behaves incorrectly without it. Sequenced last for that reason.

One point worth raising at the defense. The stated reason was that the project should be generic rather than client-specific. Configurable per-position modules are arguably *more* client-specific, not less — a generic system ships fixed roles. The feature may still be worth building; the justification runs the other way.

Sir Aldrin

Ten recommendations spanning security, data modelling, accessibility, and deployment.

Prompt-injection attacks on the assistant

[IMPLEMENTED]

> *"meron mga attacks ngayon sa AI na pinaparemove yung instructions na nandon na sinet ng programmer tas magpapasok sya ng bagong instructions"*

Confirmed by live testing, and the concern was well founded. A reply validation step that should have caught such replies was being skipped for most traffic; it now runs on **every** model answer.

The important part is *why* this works: the model still complies with the attacker and still produces the fake configuration dump. The application discards it anyway, because the check does not depend on the model choosing to obey. Request throttling was added alongside, since unlimited retries defeat probabilistic defences by definition.

Filter malicious files in the printing service

[IMPLEMENTED]

> *"dapat tinitest niyo din yung mga ina-upload don what if malicious file yon tas dinownload na yung ng brgy official for printing"*

The right concern, aimed at the riskiest path. Validation existed but trusted the **client-declared** file type, which an attacker sets freely, and the allowlist permitted the legacy Word format where auto-executing macros live.

File type is now verified from the file's own leading bytes, across print, verification, and complaint-evidence uploads. Legacy `.doc` is refused by name with advice to re-save.

```
Windows .exe renamed .pdf   → rejected
ELF binary renamed .pdf     → rejected
shell script renamed .pdf   → rejected
plain .zip renamed .docx    → rejected
legacy .doc (macro format)  → rejected, by name
genuine PDF / DOCX / image  → accepted
```

Residents typing personal information into chat

[IMPLEMENTED]

> *"pati data security isa pa yon kunyare nag add yung resident ng personal information niya don sa chat hindi niya dapat tanggapin yun"*

Every question was stored permanently for an analytics counter, so a resident pasting an ID number kept it in the database indefinitely for no purpose. Phone numbers, PhilSys numbers, emails, and long digit runs are now redacted before the record is written, while the live answer still sees the original text. Ordinary numbers — "3 copies for my 2 kids" — are untouched.

Limit complaints to barangay jurisdiction

[IMPLEMENTED]

> *"merong complaints na sa barangay lang kunyare murder hindi pwedeng barangay yun… ilimit nyo sa katarungang pambarangay complaints"*

Legally correct and entirely absent before — nothing stopped a homicide being filed as a barangay complaint, where it would have sat in a 20-day mediation queue instead of reaching the police. Reports naming serious crimes are now refused with a referral to the PNP and 911, and the limit is stated on the form before the resident starts typing.

The pattern list is deliberately narrow, because a false block sends someone away from help. Verified: "burning garbage" is *not* read as arson.

Married residents and the maiden-name mismatch

[IMPLEMENTED]

> *"pag kasi kinasal sya… iba yung sinasabi sa birth certificate mo tas yung pangalan mo ngayon… Hindi lang dapat birth certificate yung way niyo to verify"*

A sharp real-world catch. Identity matching required every name part to appear, so a married woman presenting a birth certificate in her maiden name failed through no fault of her own.

Marriage certificates are now accepted, with the name check deliberately not required on that document — a changed surname is the normal case there. Partial name matches are also reported rather than shown as a bare empty checkbox, which is the cue staff need.

```
birth certificate (maiden surname)  → 55%  PARTIAL
    □ Full name — 2 of 3 name parts matched
marriage certificate (bridges both) → 100% MATCH
```

Larger fonts and fewer icons for elderly residents

[PARTLY IMPLEMENTED]

> *"yung mga icons tatanggalin daw lakihan unti yung font kasi matatanda yung ibang gagamit"*

Type was raised one step across the shared style tokens, so the change scales proportionally everywhere rather than being patched screen by screen.

Icons were deliberately left in place, pending your decision. For elderly and lower-literacy users, icons frequently *aid* recognition rather than hinder it, so removing them could work against the same goal the recommendation is pursuing. This is a design judgement rather than a technical one, so it is flagged rather than decided unilaterally.

Filipino inquiries to the assistant

[ALREADY PRESENT]

> *"tagalog dapat nag-aaccept ng tagalog yung AI"*

Already implemented and verified live: a Filipino question returns a Filipino answer. Language detection, Filipino variants of every built-in reply, and language instruction to the model were all present. Worth demonstrating at the defense.

Household registry covering children

[ALREADY PRESENT]

> *"yung bata dapat makaregister din sya yung 15 pababa… imbes na iregister nyo yung baby… ipasok niyo sya sa household registry per family… may changes sa database yon"*

The database already supports this. Households exist as their own records with address and purok; every census entry links to one; the registry screen displays and searches by household. Minors are already carried — the sample data includes a thirteen-year-old.

His key distinction is also already honoured: the age limit applies to **creating an account**, not to census membership — exactly the separation he described. The remaining gap is presentational: a head-of-family field and a grouped household view. No database change is needed.

Test SQL injection through the chatbot

[DECLINED — NO SUCH PATH]

> *"try niyo mag set / prompt kayo ng mga sql injections sa loob ng chatbot pagka may pumasok delikado yun"*

Tested, and the result is that no execution path exists. The assistant has no database access and no tools: its reply is consumed by a pattern test, a length truncation, and escaped text in the browser. The only database write is a parameterised insert, and a review of the entire API found no shell execution or dynamic evaluation anywhere.

The underlying instinct is right and was acted on. The real risk is prompt injection, which was measured and addressed — see the first entry in this section. The guardrail he described was implemented in code rather than in prompt wording, because prompt rules against injection already existed and the model ignored them during testing.

Knowledge base should accept PDF or Word files

[DECLINED — NOT POSSIBLE]

> *"if magpapafeed ka ba sa AI naka .md file kayo so need talaga ng pdf or docs file sa knowledge base"*

Demonstrated directly on the system. The knowledge loader decodes raw bytes as text with no extraction stage, so a PDF yields page-geometry markup and compressed binary rather than words. A test PDF containing the sentence *"Barangay Clearance — 3 working days, FREE"* did not contain that sentence once decoded, because the text sits inside a compressed stream. The assistant would be grounded on layout instructions.

PDFs are also a known carrier for hidden instructions — text can be white, minute, or positioned off-page, invisible to the person uploading it but fully readable by the model.

His actual concern is valid and is answered elsewhere. Staff are not technical, and Sir Ezeck's knowledge editor solves exactly that: staff fill in a form, the system writes the file. The two recommendations resolve each other.

File links should preview only, never download

[GOAL MET, METHOD CHANGED]

> *"yung temporary URL link dapat daw walang download option don kasi preview lang sya… Pagkasend sa file ng nasa URL print agad yung lalabas"*

The goal is right; the method cannot work as described. A browser cannot display a file without the bytes reaching the device — a preview *is* a download without a save dialogue — and printing renders locally first. Promising an un-downloadable preview would be a claim the system could not keep.

What was done instead: unauthenticated file links now expire in one hour by default rather than seven days, so a leaked link stops working quickly. Sensitive documents already requested short links; the long default was the hazard for any future code that forgot to ask.

Push notifications for announcements and evacuation

[NOT YET BUILT]

> *"standard banner + evacuation use push notification… magiging progressive web app… useful sa evacuations since mabilisan yun"*

Technically sound, and free — web push requires no payment. The evacuation use case is the strongest argument for it.

Why not yet: the system has no progressive-web-app infrastructure of any kind today, so this means a manifest, a service worker, subscription storage, and a push server. It is one of the two largest items raised.

Two corrections for planning: an installed progressive web app runs in its own window rather than redirecting to the browser, and on iPhones push works only once the app is added to the home screen. Android coverage is complete; iOS is conditional.

Deployment and network architecture diagram

[IMPLEMENTED]

> *"pano yung architecture, pano yung connection sa web server, sa database server, pano iaaccess ng user para syang diagram"*

Produced as two figures: how a request reaches the system (browser → nginx → three virtual hosts), and what runs inside the Docker network with every service-to-service call labelled. Drawn from the production compose file and the nginx site configuration rather than from intent, so it reflects what actually deploys.

It also corrects an assumption from the consultation: the assistant's language model is **not** a third-party service. It runs in a container on the same machine with no published port, so resident questions never leave the server.

Found during review — not raised by the panel

Three of these outranked most consultation items on severity. All are fixed.

FINDING	WHY IT MATTERED	STATUS
Token signing keys fell back to published defaults	A production deployment missing those settings would have started normally and signed sessions with a value committed to the repository, allowing forged administrator access. It now refuses to start; development is unaffected.	Fixed
No request throttling anywhere	Unlimited password attempts, unlimited password-reset emails to any address, and unlimited assistant calls each holding an open model request — the main availability risk on a single-server deployment.	Fixed
Unauthenticated file links defaulted to seven days	Sensitive documents already requested one-hour links, so exposure was limited — but the long default meant any new code would silently inherit a week-long link.	Fixed
Census refresh lost residents who changed their surname	Import matched on exact name plus birthdate, so a resident who married appeared as a new person: her old record was deactivated — **disabling her portal account** — while an unclaimed duplicate of her identity was created. Matching now recognises a changed surname at the same birthdate and renames in place. Separately, a record linked to a registered account is no longer auto-deactivated when a row is missing from the spreadsheet; it is flagged for staff instead.	Fixed
Object storage vendor withdrew its images mid-development	MinIO's public images were removed from every registry, so the system could not start at all. Storage was migrated to an equivalent S3 service in both the development and production compose files. Because storage access sat behind a single class, no application code changed — only infrastructure configuration.	Migrated

What is not yet built

Four items: the knowledge editor, bulk registration by invitation, administrator-controlled module permissions, and push notifications — plus the deployment diagram, which is documentation rather than code. The middle two are the largest pieces of work raised in the consultation. **None of them is blocked.** Each was deferred by choice, to put defects affecting residents ahead of additions, and the honest account of why they are missing is that the schedule ran out — not that anything prevented them.

Nothing outstanding is a correctness or safety defect. Every item where the system was doing something *wrong* — the OCR score, the missing jurisdiction limit, the maiden-name failure, upload validation, the injection gap — has been fixed and verified against the running system.

Every entry was checked against the source and, where applicable, confirmed by testing the running system rather than estimated. Full regression suite: 40 of 40 passing.